

CYBERSECURITY CASE STUDY

Zero-Trust IAM with Keycloak

RBAC • TOTP MFA • PAM • JIT/JEA • Identity Governance

Alshaima Syed

Identity Security | Zero Trust | Access Governance

Portfolio Edition 1 | Advanced Network Security

Executive summary

This case study applies zero-trust identity principles to a representative critical-infrastructure organization. A Keycloak environment was deployed to model identity tiers, role-based access, user lifecycle controls and TOTP-based multi-factor authentication. The technical build was combined with credential-exposure review, physical-to-logical access analysis and vendor privilege governance.

Outcome

The project demonstrated how authentication, RBAC, MFA and privileged-access governance can be combined to reduce standing access, strengthen assurance and expose gaps across workforce, contractor and vendor identities.

Environment	Keycloak 24.0.4 in Docker Desktop on Windows 11.
Core controls	RBAC, TOTP MFA, required actions, session limits, JIT/JEA concepts, PAM and IGA.
Security focus	Zero trust, least privilege, credential risk, access review and third-party governance.
Scope	Authorized lab using synthetic organizational identities and scenarios.
Privacy	Credentials, student identifiers and classroom information are excluded.

Identity architecture

A dedicated realm represented the organization. Roles modeled business access tiers, while user assignments demonstrated centralized authorization. Authentication policy added OTP enrollment as a required action, creating a second factor beyond passwords.

Realm roles

Realm roles are the roles that you define for use in the current realm. [Learn more](#)

Search role by name	→	Create role	Refresh	1 - 7
Role name	Composite	Description		
default-roles-northgrid-energy	True	<code>\${role_default-roles}</code>		
helpdesk	False	Access to user management and basic IT support tools		
it-admin	False	Access to IT infrastructure management tools		
offline_access	False	<code>\${role_offline-access}</code>		
ot-operator	False	Access to OT monitoring dashboard and EMS read-only		
uma_authorization	False	<code>\${role_uma_authorization}</code>		
vendor-hvac	False	Scoped access to BMS subnet only – contractor role		

Figure 1. Keycloak realm-role configuration supporting centralized RBAC.

Implementation

Realm, roles and users

- Deployed Keycloak through Docker and verified the administrative environment.
- Created a dedicated organizational realm to separate identity policy and objects.
- Defined role tiers aligned to job responsibilities and least-privilege objectives.
- Created representative workforce and contractor accounts and mapped roles centrally.

☐ Username	Email	Last name	First name
☐ a.admin	–	Admin	Alex
☐ hvac.contractor	–	Contractor	HVAC
☐ j.operator	–	Operator	Jamie

Figure 2. Representative users managed within the dedicated Keycloak realm.

Multi-factor authentication

- Enabled Configure OTP as a required action for controlled enrollment.
- Positioned OTP after primary credential validation in the browser authentication flow.
- Used session timeouts and required actions as practical controls for contractor access.

Required actions	Enabled	Set as default action ?
 Configure OTP	☒ On	☐ Off

Figure 3. Configure OTP enabled as a required action.

Access-control analysis

RBAC and policy evolution

RBAC simplified consistent access assignment by connecting users to defined roles instead of granting permissions individually. For policy-based access, the design would be extended with contextual authorization rules using attributes such as device trust, location, time, resource sensitivity and risk.

Privileged and vendor access

- Replace persistent vendor access with time-bound approval and automatic expiry.
- Use PAM-controlled credential checkout, session recording and command restrictions.
- Apply JEA to limit administrative capabilities to approved tasks.
- Trigger periodic IGA access certification and immediate revocation when sponsorship ends.
- Separate emergency access from normal operations and monitor every use.

Cross-domain identity risk

Logical access should be reconciled with physical zones, employment status and vendor contracts. A person should not retain application privileges that exceed their facility access, current responsibilities or approved service window.

Workforce	Joiner-mover-leaver automation, MFA and periodic role review.
Contractor	Short sessions, required MFA, sponsor approval and expiry.
Privileged admin	PAM vaulting, JEA, monitoring and break-glass governance.
Vendor	JIT activation, restricted scope, recorded sessions and contract-linked offboarding.

Security findings and recommendations

- Persistent contractor access creates unnecessary exposure; default to disabled and activate only for approved windows.
- Passwords alone are insufficient for sensitive access; enforce phishing-resistant MFA where supported and TOTP as a minimum lab control.
- Roles require ownership, review cadence and separation-of-duties checks to prevent privilege accumulation.
- Credential-exposure services can inform password resets, but exposed-password checks must be implemented without disclosing credentials.
- Identity logs should feed the SIEM for anomalous login, role-change, MFA and privileged-session monitoring.

Skills demonstrated

IAM engineering	Keycloak deployment, realm configuration, users, roles and required actions.
Access control	RBAC implementation and contextual policy design.
Zero trust	Explicit verification, least privilege, session limits and continuous review.
Privileged access	PAM, JIT, JEA, vendor governance and recorded administration.
Risk communication	Connected technical identity controls to physical and supply-chain exposure.

Conclusion

The project moved identity from simple account administration to a layered control system. Keycloak provided the technical foundation, while lifecycle, privileged-access and cross-domain reviews addressed the governance required to keep authorization appropriate over time.

Selected references

Keycloak Documentation — <https://www.keycloak.org/documentation>
NIST SP 800-207, Zero Trust Architecture — <https://csrc.nist.gov/pubs/sp/800/207/final>
NIST SP 800-63B, Authentication and Lifecycle Management — <https://pages.nist.gov/800-63-4/sp800-63b.html>
CISA Zero Trust Maturity Model — <https://www.cisa.gov/resources-tools/resources/zero-trust-maturity-model>